



REPUBLIQUE DU CAMEROUN

PAIX – TRAVAIL – PATRIE

MINISTERE DE
L'ENSEIGNEMENT SUPERIEUR

UNIVERSITE DE YAOUNDE I

ECOLE NATIONALE SUPERIEURE
POLYTECHNIQUE DE YAOUNDE

DEPARTEMENT DE GENIE INFORMATIQUE

REPUBLIC OF CAMEROON

PEACE – WORK – FATHERLAND

MINISTRY OF
HIGHER EDUCATION

UNIVERSITY OF YAOUNDE I

NATIONAL ADVANCED SCHOOL
OF ENGINEERING

COMPUTER ENGINEERING DEPARTMENT

Matiere : **GES4062 – ANALYSE DE RISQUE, AUDIT ET GESTION DE CRISE**

Enseignant responsable : M. MINKA E.

ANALYSE DES SCENARIOS D'ATTAQUE ENTREPRISE LIZBIZ

Injection SQL · Vol de Credentials ERP · Chemins d'Attaque · Mesures Correctives

Realise par :

Noms et Prenoms	Matricule	Filiere
AYONMENE TIOBOU VARESE	22P045	CIN-4
KALDADACK ADAMA	24P824	CIN-4
MAKEU TENKU STELY B.	24P826	CIN-4
NDJEBAYI PATRICK N.	24P827	CIN-4
NGONDOUM N.ELISABETH	24P829	MSI-4
OWONO OWONO MARTIN	22P099	MSI-4
ZE MVONDO OCEANNE	22P042	CIN-4

Sous la supervision de :

M. MINKA E.

ANNEE ACADEMIQUE : 2025 / 2026

Contents

Introduction	2
1 Scenario S1 : Injection SQL	3
1.1 Description de la Vulnerabilite	3
1.2 Chemin d'Attaque	3
1.2.1 Exemple Concret de Payload d'Injection	4
1.3 Impact Potentiel sur LiZbiZ	5
1.4 Mesures Correctives	5
2 Scenario S2 : Vol de Credentials ERP	6
2.1 Description de la Vulnerabilite	6
2.2 Chemin d'Attaque Detaille	6
2.2.1 Etape 1 : Preparation de l'Attaque (Reconnaissance)	6
2.2.2 Etape 2 : Creation du Leurre (Phishing)	7
2.2.3 Etape 3 : Envoi de l'Email de Phishing	7
2.2.4 Etape 4 : Compromission des Identifiants	7
2.2.5 Etape 5 : Acces au Systeme et Exploitation	8
2.2.6 Etape 6 : Effacement des Traces	8
2.3 Impact Potentiel sur LiZbiZ	8
2.4 Mesures Correctives	9
3 Synthese et Comparaison des Scenarios	10
3.1 Tableau Comparatif	10
Conclusion	11
Glossaire	12

Chapter 0

Introduction

Dans le cadre de l'UE GES4062 — Analyse de Risque, Audit et Gestion de Crise, ce rapport presente l'analyse de deux scenarios d'attaque identifiés sur l'infrastructure de l'entreprise LiZbiZ.

Ces scenarios illustrent concrètement les risques identifiés lors de la phase d'analyse : le **Scenario S1** porte sur une attaque par injection SQL ciblant les formulaires non protégés de l'application web, et le **Scenario S2** décrit un vol de credentials ERP par phishing ciblé, exploitant l'absence de sensibilisation et de MFA.

Pour chaque scenario, nous analysons la source de menace, la vulnérabilité exploitée, le chemin d'attaque étape par étape, ainsi que les mesures correctives à mettre en place pour mitiger le risque.

Ces deux scenarios correspondent directement aux menaces **M2** (Injection SQL / Exploit web, score 12/16) et **M5** (Abus de droits / Vol de credentials, score 9/16) identifiées dans la matrice de risque LiZbiZ.

Chapter 1

Scenario S1 : Injection SQL

Attribut	Detail
Source de menace	Criminel externe
Motivation	Vol de donnees (financiere)
Menace	Attaque par injection SQL (code malveillant)
Actif cible	Base de donnees (PostgreSQL) via formulaires web
Niveau de risque	CRITIQUE

1.1 Description de la Vulnerabilite

Vulnerabilite principale : Absence d'utilisation de middleware entre l'IHM (Interface Homme-Machine) et la base de donnees. Les formulaires de saisie ne sont pas proteges et la base de donnees n'est pas securisee par l'utilisation de vues SQL.

Les failles specifiques identifiees sont les suivantes :

- **Absence de middleware** entre les couches IHM et base de donnees : les requetes SQL sont construites directement a partir des entrees utilisateur, sans validation ni echappement.
- **Formulaires de connexion non proteges** : aucune validation des caracteres speciaux saisis par l'utilisateur.
- **Absence de vues SQL** : la base de donnees expose directement ses tables, sans couche d'abstraction qui limiterait l'accès aux donnees sensibles.
- **Messages d'erreur SQL visibles** : en cas de requete malformee, le serveur retourne les erreurs SQL brutes, revelant la structure interne de la base.

1.2 Chemin d'Attaque

Le chemin d'attaque se deroule en quatre etapes successives :

Etape	Action	Détail technique
1	Reconnaissance	L'attaquant identifie un formulaire de connexion accessible depuis Internet (page de login, barre de recherche, formulaire de contact).
2	Test de vulnérabilité	Il insère des caractères de test dans les champs de saisie : apostrophe ' , guillemets '' , ou mots-clés SQL comme SELECT, DELETE, OR 1=1.
3	Confirmation	Si la page retourne une erreur SQL ou un comportement anormal, la vulnérabilité est confirmée. L'attaquant connaît alors la structure de la requête sous-jacente.
4	Exploitation	Il injecte un code SQL malveillant permettant de contourner l'authentification, d'extraire des données, de modifier ou supprimer des enregistrements, voire de prendre le contrôle du serveur.

1.2.1 Exemple Concret de Payload d'Injection

Un attaquant pourrait saisir dans le champ "mot de passe" du formulaire de connexion :

```
1 ' OR '1'='1'
```

Ce qui transforme la requête SQL originale :

```
1 SELECT * FROM users WHERE login='admin' AND password='[saisie]'
```

En requête malveillante :

```
1 SELECT * FROM users WHERE login='admin' AND password='' OR '1'='1'
```

La condition '1'='1' étant toujours vraie, l'attaquant contourne l'authentification et accède au système sans connaître le mot de passe.

1.3 Impact Potentiel sur LiZbiZ

Dimension	Impact
Confidentialite	Exfiltration de la base clients (10 000 fiches), donnees de paiement soumises PCI-DSS, historique des transactions.
Integrite	Modification des commandes, creation de faux paiements, alteration des donnees comptables.
Disponibilite	Suppression de tables critiques (DROP TABLE), rendant l'ERP et le site Magento inoperants.
Reglementaire	Violation RGPD immediate (notification CNIL sous 72h), exposition PCI-DSS, risque de sanction jusqu'a 4% du CA.
Reputation	Impact boursier direct pour une entreprise cotee, perte de confiance des clients.

1.4 Mesures Correctives

Mesures Correctives — Injection SQL

1. **Utiliser des requetes parametrees (Prepared Statements) :** Ne jamais concatener directement les entrees utilisateur dans une requete SQL.

```

1 # Mauvais (vulnerable)
2 query = "SELECT * FROM users WHERE login='" + login + "'"
3
4 # Correct (securise)
5 cursor.execute("SELECT * FROM users WHERE login = %s", (
    login,))

```

2. **Mettre en place un middleware de validation :** Valider et assainir toutes les entrees utilisateur avant tout traitement (bibliotheques ORM : SQLAlchemy, Hibernate, Doctrine).
3. **Creer des vues SQL restrictives :** Les applications ne doivent acceder qu'aux vues, jamais directement aux tables. Les vues exposent uniquement les colonnes necessaires.
4. **Desactiver les messages d'erreur SQL** en production : configurer le serveur pour retourner des erreurs generiques, jamais le detail SQL.
5. **Mettre en place un WAF** (Web Application Firewall) capable de detecter et bloquer les tentatives d'injection SQL.
6. **Principe du moindre privilege :** Le compte de base de donnees utilise par l'application doit avoir uniquement les droits SELECT/INSERT/UPDATE necessaires, jamais DROP ou ALTER.

Chapter 2

Scenario S2 : Vol de Credentials ERP

Attribut	Detail
Source de menace	Cybercriminel externe / groupe organise
Motivation	Financiere (fraude, revente de donnees, acces ERP)
Menace	Vol d'identifiants (credentials) par phishing cible
Actif cible	Systeme ERP Odoo v15 (comptes utilisateurs)
Niveau de risque	ELEVE

2.1 Description de la Vulnerabilite

Les vulnerabilites exploitees dans ce scenario sont de nature organisationnelle et technique :

- **Sensibilisation insuffisante des utilisateurs** : Les employes ne sont pas formes a reconnaitre les tentatives de phishing. Ils font confiance aux emails apparemment legitimes.
- **Politique de mot de passe faible** :
 - Mots de passe simples (date de naissance, prenom)
 - Longueur insuffisante (moins de 8 caracteres)
 - Caractere unique (uniquement des chiffres ou lettres)
 - Reutilisation du meme mot de passe sur plusieurs comptes
- **Absence d'IDS/IPS** : Aucun systeme de detection ou prevention d'intrusion n'est en place pour alerter sur les connexions suspectes.
- **Absence de MFA** : L'authentification multi-facteurs n'est pas activee sur l'ERP, permettant a tout deteneur des identifiants de se connecter sans verification supplementaire.

2.2 Chemin d'Attaque Detaille

Ce scenario se deroule en six etapes :

2.2.1 Etape 1 : Preparation de l'Attaque (Reconnaissance)

L'attaquant collecte des informations sur LiZbiZ via des sources ouvertes (OSINT) :

- Consultation du profil LinkedIn de l'entreprise pour identifier les employes et leurs fonctions (ex. : comptable, logisticien)

- Analyse du site web pour extraire le schema d'adresses email (ex. : prenom.nom@lizbiz.com)
- Identification d'une cible prioritaire : un employe avec acces aux fonctions financieres de l'ERP

2.2.2 Etape 2 : Creation du Leurre (Phishing)

L'attaquant prepare une infrastructure de phishing :

- Creation d'une fausse page de connexion ERP visuellement identique a l'originale (copie CSS/HTML du vrai portail)
- Enregistrement d'un domaine trompeur :

Type	URL
Faux site (attaquant)	erp-lizbiz-security.com
Vrai site (legitime)	erp.lizbiz.com

2.2.3 Etape 3 : Envoi de l'Email de Phishing

L'attaquant envoie l'email suivant a la cible identifiee :

De : security@erp-lizbiz-security.com

Objet : *[URGENT] Mise a jour obligatoire de votre compte ERP*

Bonjour,

Suite a une mise a jour de securite, veuillez vous reconnecter immediatement pour eviter la suspension de votre acces.

[Cliquez ici pour securiser votre compte](#)

L'equipe Securite LiZbiZ

2.2.4 Etape 4 : Compromission des Identifiants

1. L'employe clique sur le lien contenu dans l'email
2. Il arrive sur la fausse page de connexion (identique visuellement au vrai ERP)
3. Il saisit son login et son mot de passe
4. Les identifiants sont envoyes **directement a l'attaquant** via un script PHP sur le serveur malveillant
5. L'employe est redirige vers le vrai ERP pour ne pas eveiller les soupcons

2.2.5 Etape 5 : Acces au Systeme et Exploitation

L'attaquant utilise les identifiants reels voles pour se connecter au vrai ERP :

- **Aucun MFA ne bloque l'accès** : la connexion reussit immediatement
- **Aucun IDS/IPS ne detecte** la connexion depuis une IP inhabituelle

Selon ses objectifs, l'attaquant peut alors :

Objectif	Action realisable
Espionnage	Consulter les donnees clients, contrats, donnees financieres
Fraude financiere	Modifier des factures, creer de faux paiements
Exfiltration	Telecharger toute la base de donnees
Sabotage	Supprimer ou corrompre des enregistrements critiques
Revente	Vendre les donnees clients sur le dark web

2.2.6 Etape 6 : Effacement des Traces

Pour rendre l'attaque non detectable, l'attaquant :

- Supprime les logs de connexion sur le serveur malveillant
- Utilise un VPN ou le reseau Tor pour masquer son adresse IP réelle
- Opere aux heures de faible activite (nuit, week-end) pour minimiser les chances de detection en temps reel

2.3 Impact Potentiel sur LiZbiZ

Dimension	Impact
Confidentialite	Acces complet aux donnees clients, fournisseurs, donnees financieres et strategiques de l'entreprise.
Integrite	Modification des donnees comptables, creation de faux virements, falsification des stocks.
Financier	Fraudes directes, penalites RGPD et PCI-DSS pouvant atteindre 4% du CA annuel (45M euros).
Reglementaire	Violation RGPD (donnees clients), possible violation LPM si classification OIV confirmee.
Reputation	Atteinte a l'image de marque, impact cours boursier, perte de confiance des partenaires et clients.

2.4 Mesures Correctives

Mesures Correctives — Vol de Credentials

1. **Activer le MFA (Multi-Factor Authentication)** sur tous les acces ERP sans exception : un second facteur (SMS, application d'authentification, cle physique FIDO2) bloque l'attaquant meme s'il possede les identifiants.
2. **Imposer une politique de mot de passe robuste :**
 - Longueur minimale : 12 caracteres
 - Combinaison obligatoire : majuscules, minuscules, chiffres, caracteres speciaux
 - Interdiction de reutilisation des 10 derniers mots de passe
 - Renouvellement automatique tous les 90 jours
3. **Deployer un programme de sensibilisation anti-phishing :**
 - Formation annuelle obligatoire pour les 150 employes
 - Campagnes de phishing simule pour tester la vigilance
 - Procedure claire de signalement des emails suspects
4. **Mettre en place un IDS/IPS :** Detection des connexions depuis des adresses IP inconnues, alertes sur les heures de connexion inhabituelles, blocage automatique apres plusieurs echecs d'authentification.
5. **Implementer un filtre anti-phishing** sur la messagerie (SPF, DKIM, DMARC) pour bloquer les emails usurpant le domaine LiZbiZ.
6. **Monitoring des acces ERP :** Journal d'audit des connexions, alertes sur les acces en dehors des horaires de travail, detection des telechargements massifs de donnees.

Chapter 3

Synthese et Comparaison des Scenarios

3.1 Tableau Comparatif

Critere	S1 — Injection SQL	S2 — Vol de Credentials
Type d'attaque	Technique (exploit applicatif)	Sociale + technique (phishing)
Source de menace	Criminel externe	Cybercriminel / groupe organise
Vecteur d'entree	Formulaire web non protege	Email de phishing cible
Vulnerabilite cle	Absence de middleware / requetes parametrees	Absence de MFA + faible sensibilisation
Difficulte technique	Moyenne (outils automatises disponibles)	Faible (kits de phishing accessibles)
Detection	Possible via logs SQL / WAF	Difficile sans IDS/IPS
Impact potentiel max	Exfiltration BDD complete	Controle total de l'ERP
Niveau de risque	12/16 — Critique	9/16 — Eleve
Correctif prioritaire	Requetes parametrees + WAF	MFA + sensibilisation

Chapter 3

Conclusion

L'analyse de ces deux scenarios d'attaque revele une constante fondamentale en securite des systemes d'information : **les attaques les plus devastatrices exploitent presque toujours des vulnerabilites connues et corrigeables.**

L'injection SQL (S1) et le vol de credentials par phishing (S2) figurent systematiquement dans le Top 10 de l'OWASP et dans les rapports annuels des agences de cybersecurite (ANSSI, CISA). Pourtant, ces attaques continuent de reussir car les mesures correctives — souvent simples — ne sont pas implementees.

Pour LiZbiZ, la priorite immediate est double :

1. **Correction technique (S1) :** Auditer l'integralite des formulaires web et migrer vers des requetes parametrees avant toute mise en production d'une nouvelle fonctionnalite.
2. **Correction organisationnelle (S2) :** Activer le MFA sur tous les acces critiques et lancer le programme de sensibilisation anti-phishing dans les 30 prochains jours.

Ces deux scenarios renforcent la necessite d'une gouvernance de la securite formalisee (RSSI nomme, RACI en place, Comite de Securite actif) pour garantir que ces mesures correctives sont decidees, implementees et suivies dans des delais maîtrises.

Chapter 3

Glossaire

SQL	Structured Query Language — langage de gestion des bases de données relationnelles
Injection SQL	Technique d'attaque consistant à insérer du code SQL malveillant dans un champ de saisie
Middleware	Couche logicielle intermédiaire entre l'IHM et la base de données
WAF	Web Application Firewall — pare-feu applicatif protégeant les applications web
ORM	Object-Relational Mapping — outil de correspondance objet-relationnel
Phishing	Technique d'hameçonnage par email usurpant l'identité d'une entité de confiance
MFA	Multi-Factor Authentication — authentification multi-facteurs
Credentials	Identifiants de connexion (login + mot de passe)
IDS	Intrusion Detection System — système de détection d'intrusion
IPS	Intrusion Prevention System — système de prévention d'intrusion
OSINT	Open Source Intelligence — renseignement à partir de sources ouvertes
ERP	Enterprise Resource Planning — logiciel de gestion intégrée
OWASP	Open Web Application Security Project — référentiel de sécurité applicative
SPF/DKIM/DMARC	Protocoles d'authentification des emails pour lutter contre l'usurpation
CVE	Common Vulnerabilities and Exposures — base de données des vulnérabilités connues
RGPD	Règlement Général sur la Protection des Données
PCI-DSS	Payment Card Industry Data Security Standard